IN-HOUSE PROJECT · B.TECH CSE (CYBER SECURITY)

AI-Based User & Entity Behaviour Analytics System

Learning what normal looks like, and catching what isn't



Amaan Saify
7th Semester · Batch 2023–2027

Tarun Jadhav
7th Semester · Batch 2023–2027

Under the supervision of Dr. Rathnakar Achary, Associate Professor
Alliance School of Advanced Computing · Alliance University, Bengaluru

Attackers who log in look like employees

Signature-based tools

Is this a known-bad pattern?

- Match known malware and attack signatures
- Miss stolen passwords and insiders
- Miss techniques never seen before

Behaviour analytics (UEBA)

Is this normal for this person?

- Learn each user's and device's habits
- Flag unusual hours, places and volumes
- Catch first-time and out-of-character actions

Real attack patterns the system is built to catch

- A finance user logs in at 2:20 am and reads payroll
- An employee uploads 3.3 GB to a new website
- A sales account suddenly runs admin commands

What we set out to build



Learn

A personal and a department baseline for every user and device, from their own history



Detect

Statistics, machine learning and threat rules together, with no labelled attacks needed



Explain

Every alert says why in plain numbers, mapped to MITRE ATT&CK techniques



Operate

A working security console: log collection, cases, roles, audit and notifications

Built with Python · pandas · scikit-learn · Streamlit · SQLite · Plotly · Ollama (local language model)

Where existing research falls short

Capability	Reviewed work (IEEE TIFS, TII, ACM TOPS)	This project
Needs labelled attacks?	Yes - DD-GCN, LAN train on known insiders	**No - fully unsupervised + rules**
Who is profiled	Users only, or hosts only	**Users and devices together**
Explains the alert	Score only	**Plain-English reasons + ATT&CK**
False-alarm control	Euler: AUC 0.99 but precision 0.006	**Layers must agree before an alert**
Usable day to day	Offline experiments	**Live console, incremental scoring**

The techniques exist. The contribution is combining them into one explainable, label-free system you can actually run.

From raw logs to an explained alert

Collect

Linux auth.log, Windows .evtx / Sysmon, web proxy, CSV

Normalise

One common format; columns mapped automatically

Profile

44 user + 19 device features per day

Detect

Stats + ML ensemble + 33 rules

Score

0-100 risk; alert at 45+

Respond

Cases, AI summary, notifications

Logs arrive by upload, a watched drop folder, an authenticated REST API or an endpoint agent. New data is scored incrementally in seconds, identical to a full re-run.

Three layers that must agree

Behavioural statistics

- Robust z-scores against the person's own history and their department peers
- Plain evidence: "3,300 MB uploaded vs usual 1.2"

Machine-learning ensemble

- Isolation Forest
- Local Outlier Factor
- Neural-network autoencoder
- Unsupervised: trained on normal days only

Threat rules

- 33 rules mapped to MITRE ATT&CK
- Brute force, impossible travel, exfiltration
- Log clearing, encoded PowerShell, USB

Fused into one 0-100 risk score. The threshold is set so one statistic alone can never raise an alert - ML or a rule must back it up. Suspicious days are never learned as normal.

A local language model explains every case

What happened: Maria Singh, an IT-Admin, engaged in multiple suspicious activities, including tampering with security logs, creating accounts, accessing unusual resources, and using PowerShell commands that could indicate malicious intent.

How serious: This is highly likely a real threat. The combination of severe log tampering, multiple unusual activities, and the use of PowerShell commands that can hide or download malware strongly suggest malicious behavior. The detector scores, especially the threat rules score of 1.00, indicate a high risk. An innocent explanation, such as a user testing new administrative permissions, is unlikely given the volume and variety of suspicious actions.

Next steps:

- Review the specific log entries for the 11 unusual file accesses and 4 account creations.
- Check the device not in the asset inventory for any known vulnerabilities.
- Investigate the shared folders opened for the first time to determine their origin.
- Monitor Maria Singh's activities for any further suspicious behavior.
- Notify the IT department to isolate the affected systems and devices.

AI-generated by qwen2.5:7b (local) from the detector findings above - verify before acting.

Regenerate

Real output from the console: case maria.singh, security log tampering



Qwen 2.5 7B through Ollama

Runs on the laptop - no log data leaves the machine



Case summaries

What happened, how serious, 3-5 next steps



Command explainer

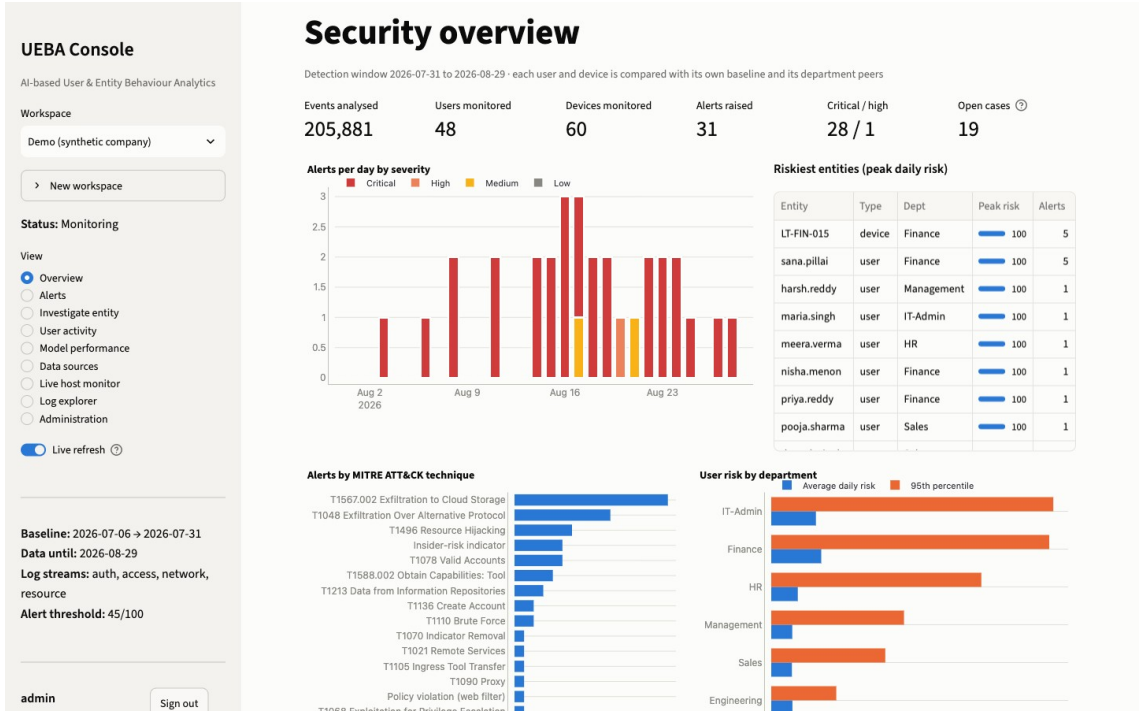
What a PowerShell or sudo command does and why it is risky



Explains, never decides

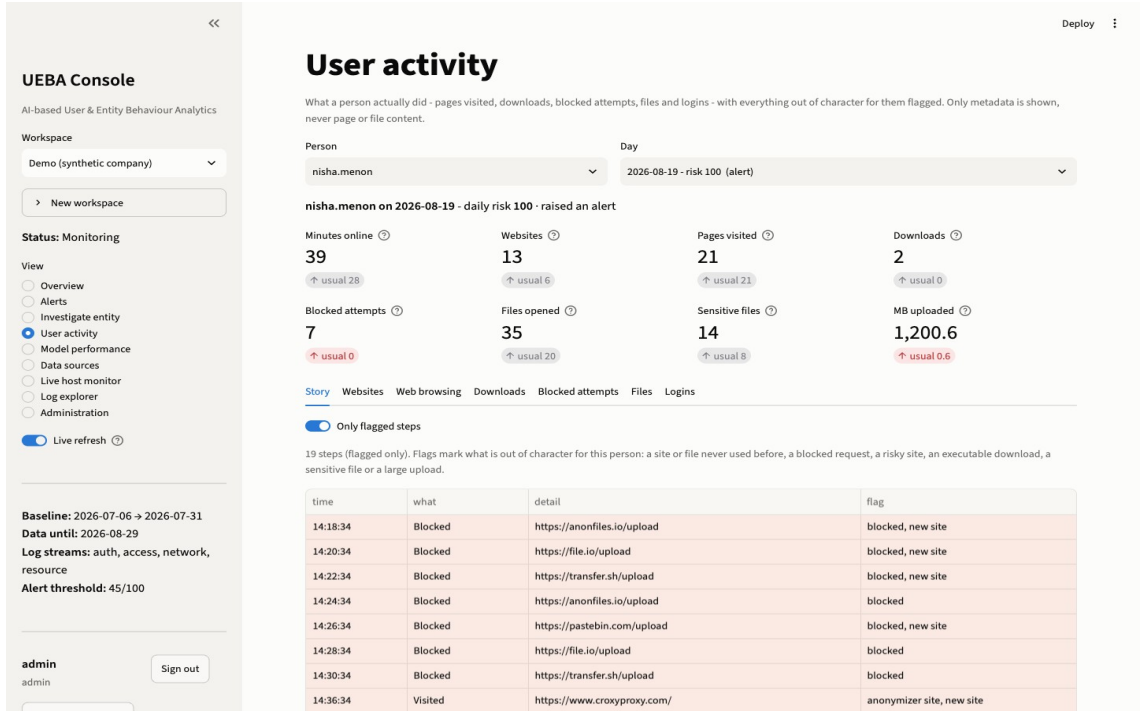
Alerts come only from the detectors; log text is fenced off against prompt injection

A security console analysts can work in



Overview

Alerts per day, riskiest people, MITRE techniques, risk by department



User activity

What a person did that day - sites, downloads, blocks, files, USB, PowerShell - out-of-character steps flagged

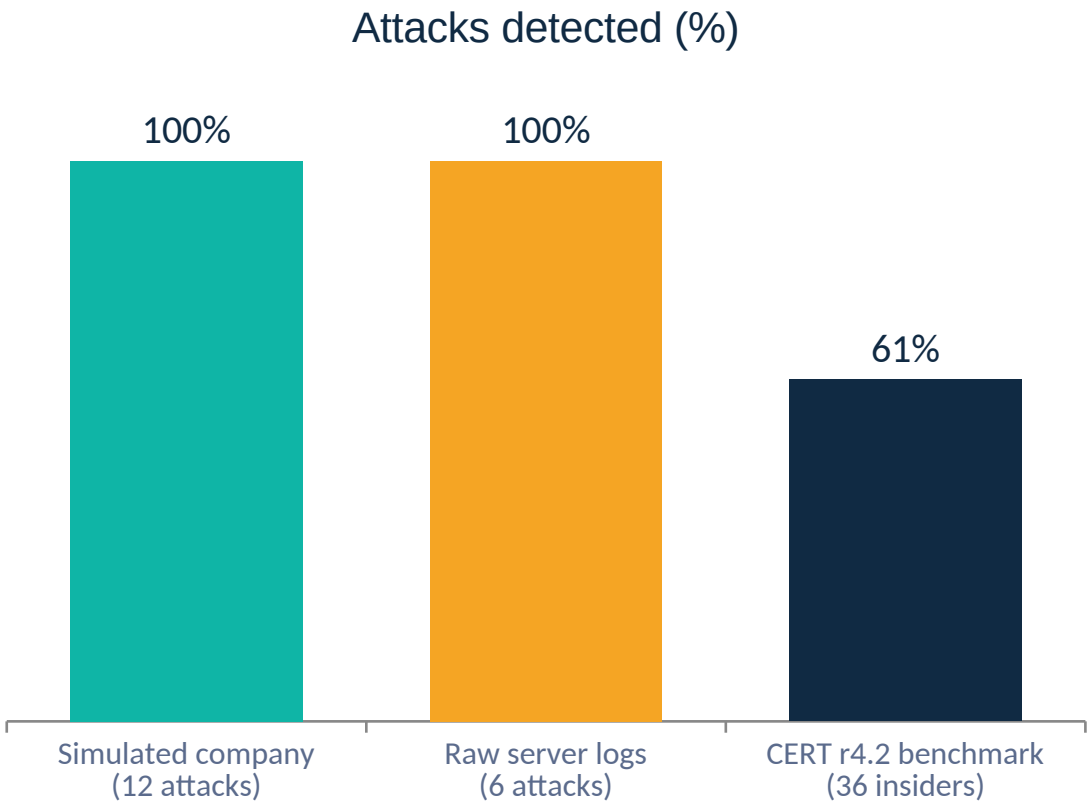
It catches the attacks, with very few false alarms

12 / 12 planted attacks caught on day one

0.95 F1 score (precision 0.94, recall 0.97)

1 alert per day on average

6 / 6 attacks found in raw Linux, Windows and proxy logs



CERT r4.2: public CMU insider-threat data we did not design - 22 of 36 held-out insiders at under one alert a day.

A security tool has to be secure itself

Salted password hashes

PBKDF2-SHA256, 310,000 iterations

Lock-out

5 failed logins lock the account for 15 minutes

Roles

Viewer, analyst, admin - each sees only what it may change

Scoped API tokens

One workspace per token, revocable, stored hashed

Audit trail

Every login, verdict, upload and setting change recorded

44 automated tests

Including: incremental update = full re-run

What we would improve next

Limitations

- Main results use a simulated company - hence the independent CERT benchmark
- Slow, gradual data theft (job-seeking insiders) is still mostly missed
- Registry, DLL and Active Directory events are not analysed yet

Future work

- Sequence-aware models for gradual insiders (LSTM / transformer over daily activity)
- More log sources: registry, cloud apps (Microsoft 365, Google Workspace)
- Let the AI assistant answer questions over the data and draft incident reports

Behaviour, not signatures

- Learns normal for every user and device - no attack labels needed
- Catches attacks early with about one alert a day, each explained
- Reads real Linux, Windows and proxy logs and runs as a working console
- Machine learning detects; a local language model explains

Thank you

Questions?

Amaan Saify · Tarun Jadhav · Supervisor: Dr. Rathnakar Achary · Alliance University, Bengaluru